

Security Assessment Report – [REDACTED]

Target: [REDACTED] Web Application

Prepared by: Aliaksei Kalcheuski

Date: April 16, 2026

Assessment Type: Web Application Penetration Testing

Overall Risk Rating: CRITICAL

1. Executive Summary:

1.1 Overview

This report details the results of a security assessment conducted on the "[REDACTED]" web application. The testing focused on identifying vulnerabilities that could be exploited by an attacker to compromise sensitive user data or gain unauthorized administrative control.

1.2 Critical Findings

The assessment identified several high-impact security flaws. Most notably, a legacy API endpoint (**/api/v1/users**) was discovered, which allows unauthenticated access to the complete user database. This leak exposes unique identifiers (IDs), roles, and contact information for all users.

Furthermore, the primary API (**/api/v2/users**) is vulnerable to Insecure Direct Object Reference (IDOR). By manipulating user IDs in API requests, an authenticated attacker can access sensitive profiles of other users, including the system administrator (ID:0). These flaws, combined with improper session termination and mass assignment vulnerabilities, indicate a critical failure in the application's access control mechanisms.

1.3 Impact & Recommendations

The combination of these vulnerabilities enables an attacker to enumerate users, extract sensitive data, and target administrative accounts for further compromise. The identified vulnerabilities may allow for large-scale data exfiltration and potential administrative account takeover. It is strongly recommended to decommission the legacy API immediately and implement strict server-side authorization checks for all object-level requests in the current API version.

2. Vulnerability Summary:

ID	Vulnerability	Severity	CVSS	Description
VULN-01	API v1 Data Exposure	Critical	9.5	Unauthenticated access to user database
VULN-02	IDOR in API v2	Critical	9	Unauthorized access to user profiles
VULN-03	Mass Assignment	High	8	Account activation bypass
VULN-04	Broken Logout	High	7.5	Session remains valid after logout
VULN-05	User Enumeration	Low	4	Different error messages reveal valid users

3. Scope and Methodology:

The testing was performed on the following environment:

- Target URL: d1bbdd5e-ee52-4044-93eff2620082f3a2.[REDACTED]
- Testing Methodology: Manual security testing using Burp Suite.

4. Technical Findings:

4.1 VULN-01: API v1 Data Exposure

- Severity: CRITICAL (CVSS: 9.5)
- Vulnerability Type: Sensitive Data Exposure / Broken Access Control

Description: The application exposes a legacy API endpoint at `/api/v1/users` which completely lacks authentication and authorization checks.

Steps to Reproduce:

1. Intercept HTTP traffic using Burp Suite.
 - Send an unauthenticated GET request to `https://d1bbdd5e-ee52-4044-93eff2620082f3a2.[REDACTED] api/v1/users`

2. Observe the 200 OK response containing a complete JSON array of all registered users in the system, including administrative accounts.

Impact: An attacker can anonymously download the entire user database, exposing sensitive personally identifiable information, user IDs, and system roles.

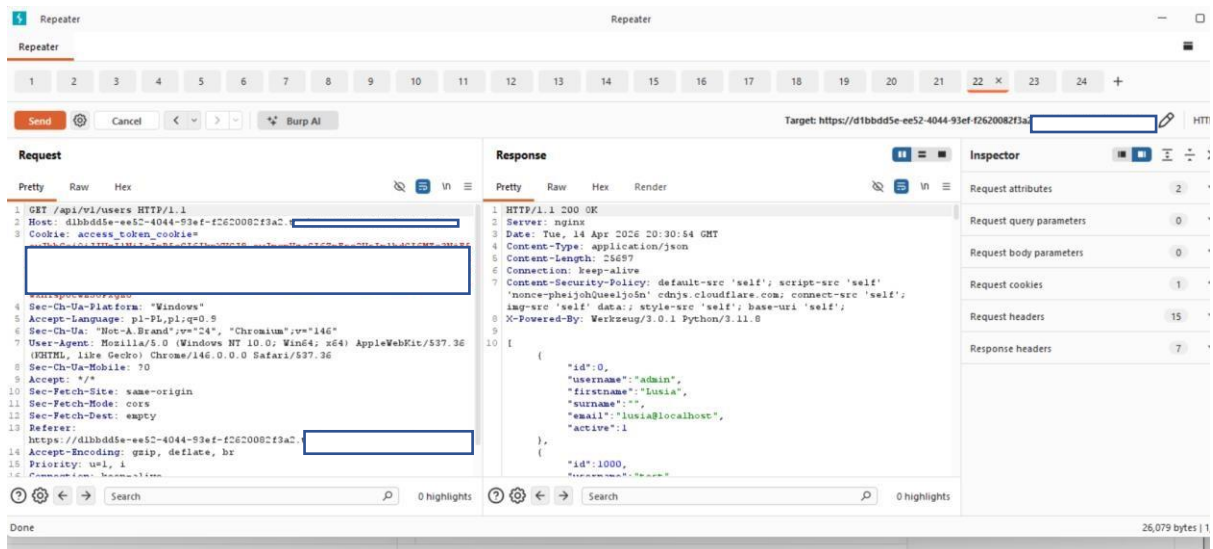


Figure 1: Full user database disclosure via API v1

4.2 VULN-02: Insecure Direct Object Reference (IDOR) in API v2

- Severity: CRITICAL (CVSS: 9.0)
- Vulnerability Type: IDOR / Broken Access Control

Description: The primary API endpoint for retrieving user profiles (/api/v2/users/{id}) fails to implement object-level access control. It relies solely on the user being authenticated but does not verify if the requested user ID matches the token's owner.

Steps to Reproduce:

1. Authenticate to the application as a standard, low-privileged user.
2. Intercept the profile retrieval request in Burp Suite Repeater.
3. Modify the endpoint URL to request the administrator's ID: GET /api/v2/users/0
4. The server responds with a 200 OK status, revealing the administrator's private profile details (e.g., email: lusia@localhost.net).

Impact: Any authenticated attacker can view the personal data of any other user on the platform, leading to complete horizontal and vertical privilege escalation regarding data access.

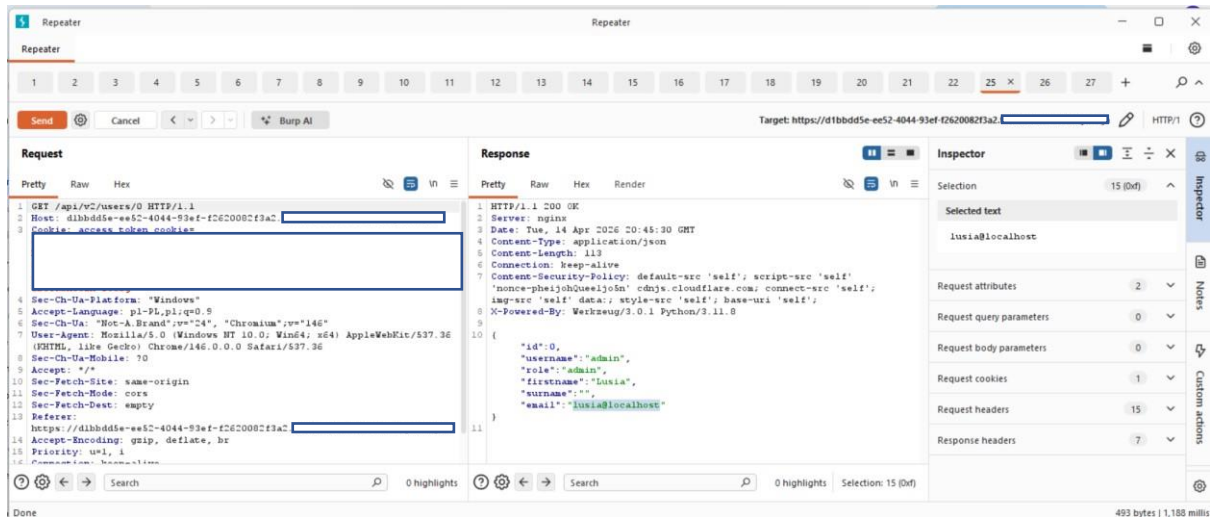


Figure 2: Unauthorized access to Admin profile (ID: 0) via IDOR

4.3. VULN-03: Account Activation Bypass via Mass Assignment

- Severity: HIGH (CVSS: 8.0)
- Vulnerability Type: Mass Assignment / Business Logic Flaw

Description: The user registration endpoint (POST `/api/v2/register`) implicitly binds client-provided JSON parameters directly to the database object without proper filtering. This allows an attacker to inject restricted fields during account creation.

Steps to Reproduce:

1. Initiate the account registration process.
2. Intercept the POST request in Burp Suite.
3. Inject the unauthorized parameter `"active": 1` into the JSON payload.
4. Forward the request. The account is created and fully activated, bypassing the intended administrative or email verification flow.

Impact: Attackers can create an unlimited number of fully active malicious accounts automatically, bypassing primary anti-spam and security verification mechanisms.

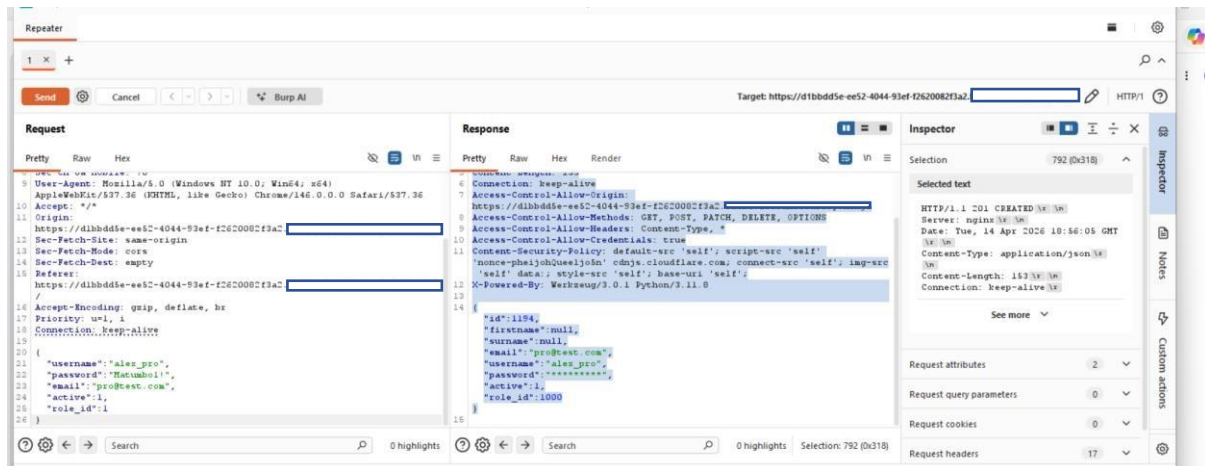


Figure 3: Successful account activation bypass via Mass Assignment

4.4. VULN-04: Broken Session Management (Failed Logout)

- Severity: HIGH (CVSS: 7.5)
- Vulnerability Type: Broken Authentication / Insecure Session Handling

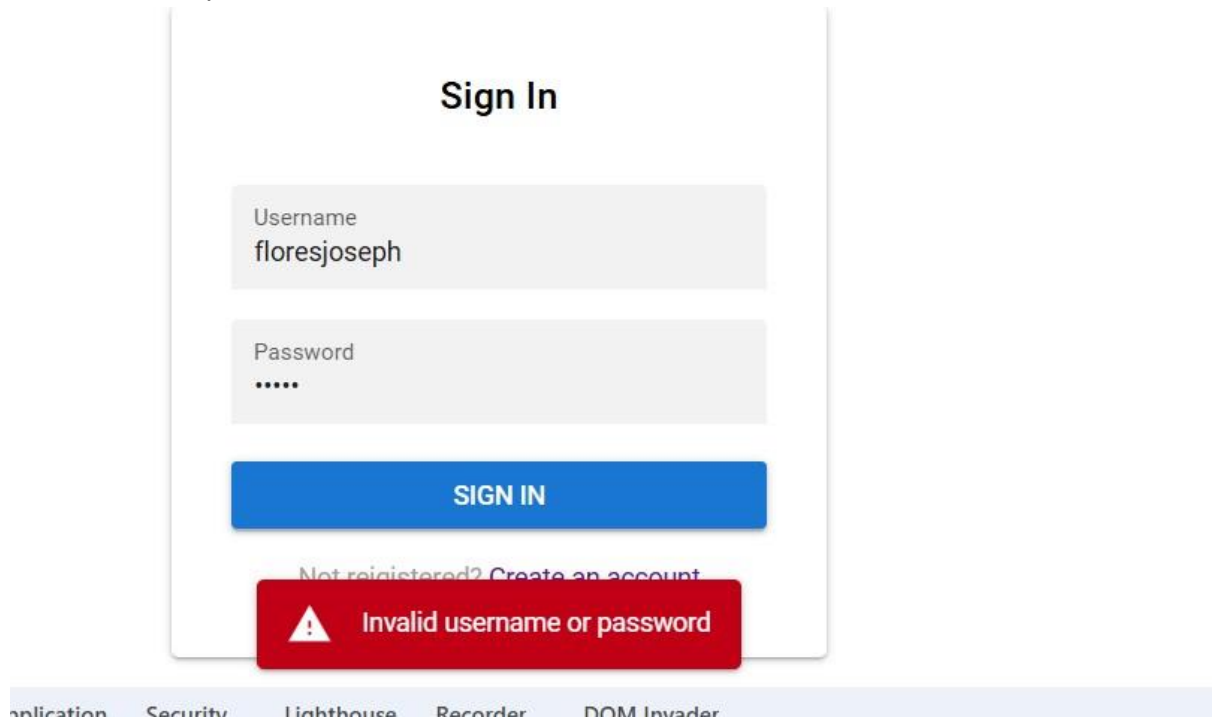
Description: The application fails to properly invalidate session tokens (JWT/Cookies) on the server side when a user logs out.

Steps to Reproduce:

1. Log in to the application and capture a valid authenticated request in Burp Suite.
2. Click the "Logout" button in the web interface to terminate the session.
3. Replay the previously captured request using the "logged out" session token.
4. The server processes the request successfully, proving the token is still alive.

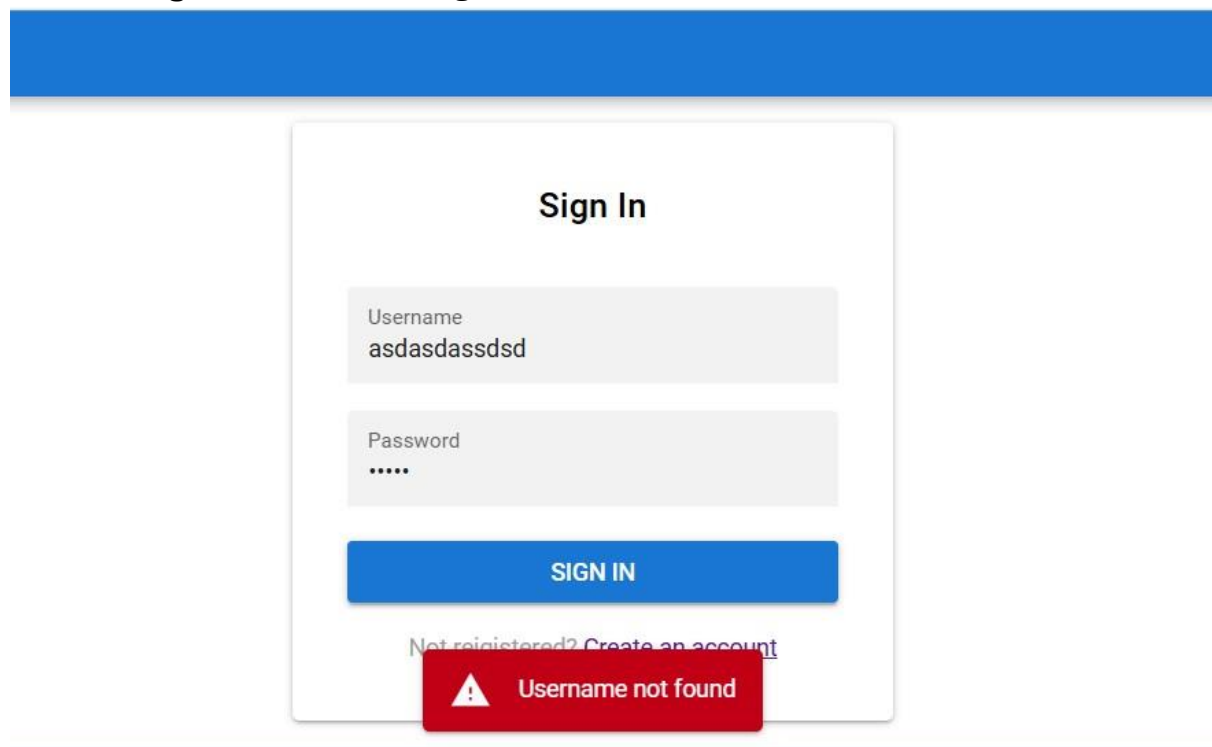
Impact: If a session token is intercepted via XSS or network sniffing, an attacker can maintain persistent access to the victim's account even after the victim attempts to log out and secure their session.

Proof of Concept:



The screenshot shows a web application interface with a 'Sign In' form. The form has two input fields: 'Username' with the value 'floresjoseph' and 'Password' with masked characters '.....'. Below the fields is a blue 'SIGN IN' button. Under the button, there is a link that says 'Not registered? Create an account'. A red error message box is displayed at the bottom of the form, containing a warning icon and the text 'Invalid username or password'. The browser's developer tools are visible at the bottom, showing tabs for 'Application', 'Security', 'Lighthouse', 'Recorder', and 'DOM Invader'.

Figure 5a: Error message returned when a valid username is entered



The screenshot shows the same 'Sign In' form as in Figure 5a. The 'Username' field now contains 'asdasdassdsd'. The 'Password' field remains masked. The blue 'SIGN IN' button is still present. The red error message box at the bottom now displays a warning icon and the text 'Username not found'. The browser's developer tools are still visible at the bottom.

Figure 5b: Error message returned for a non-existent username, confirming its absence in the database.

5. Remediation Recommendations:

5.1 Short-term Actions (Fix Now)

- VULN-01 (API v1 Leak): Immediately disable or remove the `/api/v1/` route from the production environment.
- VULN-02 (IDOR): Implement server-side authorization checks for the `/api/v2/users/{id}` endpoint. Ensure the server verifies that the requesting user's ID matches the ID in the URL.
- VULN-03 (Mass Assignment): Use a DTO (Data Transfer Object) or an "allow-list" for input parameters in the registration process to prevent users from setting internal fields like `active` or `role_id`.

5.2 Strategic Improvements

- Session Management: Update the logout function to invalidate tokens on the server side (e.g., using a blacklist or reducing JWT lifespan).
- Error Handling: Implement generic error messages for the login form (e.g., "Invalid credentials") to prevent account enumeration.
- Security Audits: Integrate automated security scanning into the CI/CD pipeline to catch legacy API exposures and common OWASP Top 10 flaws early.

6. Conclusion:

The security assessment of the " [REDACTED] " application revealed critical vulnerabilities that pose a significant risk to user data confidentiality and system integrity. By implementing the provided recommendations, the development team can substantially improve the application's security posture and protect against unauthorized access.